

API 设计规范文档

1. 全局规范定义

1.1 统一响应结构

系统所有 API 接口（无论请求成功与否）均采用统一的 JSON 包装格式进行返回：

```
{
  "code": 200,
  "message": "success",
  "data": {}
}
```

- code: 业务状态码（200 表示成功，非 200 表示各类业务或系统异常）。
- message: 提示信息，可直接用于前端弹窗展示。
- data: 实际业务载荷数据。请求失败时，此字段可为 null 或空对象。

1.2 全局错误码字典

错误码	描述说明	触发场景说明
200	请求成功	正常返回
400	参数校验失败	必填项为空、格式不合法、长度越界等
401	未认证或凭证失效	未携带 Token 或 Token 已过期
403	无权限操作	尝试操作不属于当前用户的资源
404	资源不存在	查询的订单、需求或用户 ID 不存在
500	服务端异常	数据库连接失败、运行时未知错误等

2. 核心业务接口

2.1 用户登录

- **URL 路径:** /api/v1/auth/login
- **HTTP 方法:** POST
- **安全认证:** 不需要

请求参数 (Body):

字段	类型	必填	说明
username	String	是	用户名或学号，长度 4-20 位
password	String	是	用户密码（前端需进行 SHA256 加密后传输）

响应格式示例 (成功):

```
{
  "code": 200,
  "message": "登录成功",
  "data": {
    "userId": "10086",
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6I.."
```

响应格式示例 (失败 - 密码错误):

```
{
  "code": 400,
  "message": "用户名或密码错误",
  "data": null
}
```

2.2 发布需求

- **URL 路径:** /api/v1/requirements
- **HTTP 方法:** POST
- **安全认证:** 需要 Header 携带 Authorization: Bearer <token>

请求参数 (Body):

字段	类型	必填	说明
title	String	是	需求标题，限 5-50 字符
description	String	是	需求详细描述，限 500 字符
budget	Decimal	是	预算金额，必须 >= 0
type	String	是	需求分类枚举（如 EXPRESS, TUTORING）

响应格式示例 (成功):

```
{
  "code": 200,
  "message": "发布成功",
  "data": {
    "reqId": "REQ_992103"
  }
}
```

响应格式示例 (失败 - 预算金额为负数等参数校验失败):

```
{
  "code": 400,
  "message": "预算金额必须大于等于0",
  "data": null
}
```

2.3 浏览需求列表（含筛选）

- URL 路径: /api/v1/requirements
- HTTP 方法: GET
- 安全认证: 需要 Header 携带 Authorization: Bearer <token>

请求参数 (Query):

字段	类型	必填	说明
keyword	String	否	标题或描述的模糊搜索词

字段	类型	必填	说明
status	String	否	状态筛选（如 PENDING 待接单）
page	Integer	否	当前页码，默认 1
pageSize	Integer	否	每页数量，默认 10，最大 50

响应格式示例 (成功):

```
{
  "code": 200,
  "message": "success",
  "data": {
    "total": 150,
    "list": [
      {
        "reqId": "REQ_992103",
        "title": "求代拿快递",
        "budget": 5.00,
        "status": "PENDING"
      }
    ]
  }
}
```

响应格式示例 (失败 - Token 失效或未携带):

```
{
  "code": 401,
  "message": "登录凭证已过期，请重新登录",
  "data": null
}
```

2.4 接单 (基于需求创建订单)

- URL 路径: /api/v1/orders
- HTTP 方法: POST
- 安全认证: 需要 Header 携带 Authorization: Bearer <token>

请求参数 (Body):

字段	类型	必填	说明
reqId	String	是	想要接单的需求 ID

专属错误码:

- 4001: 该需求已被他人接单。
- 4002: 发布者不可接取自身发布的需求。

响应格式示例 (成功):

```
{
  "code": 200,
  "message": "接单成功",
  "data": {
    "orderId": "ORD_558291"
  }
}
```

响应格式示例 (失败 - 需求已被抢单):

```
{
  "code": 4001,
  "message": "手慢了，该需求已被他人接取",
  "data": null
}
```

2.5 查看订单详情

- **URL 路径:** /api/v1/orders/{orderId}
- **HTTP 方法:** GET
- **安全认证:** 需要 Header 携带 Authorization: Bearer <token>

请求参数 (Path):

字段	类型	必填	说明
orderId	String	是	订单的唯一标识 ID

响应格式示例 (成功):

```
{
  "code": 200,
  "message": "success",
  "data": {
    "orderId": "ORD_558291",
    "reqId": "REQ_992103",
    "publisherId": "10086",
    "receiverId": "10087",
    "amount": 5.00,
    "currentState": "IN_PROGRESS"
  }
}
```

响应格式示例 (失败 - 订单不存在):

```
{
  "code": 404,
  "message": "查询的订单不存在",
  "data": null
}
```

2.6 提交评价

- **URL 路径:** /api/v1/orders/{orderId}/evaluations
- **HTTP 方法:** POST
- **安全认证:** 需要 Header 携带 Authorization: Bearer <token>

请求参数 (Body):

字段	类型	必填	说明
star	Integer	是	评分星级，限制 1 到 5 之间的整数
content	String	否	文字评价内容，限 200 字符内

响应格式示例 (成功):

```
{
  "code": 200,
  "message": "评价提交成功",
  "data": null
}
```

响应格式示例 (失败 - 订单不存在):

```
{
  "code": 4003,
  "message": "订单尚未完成, 暂不可提交评价",
  "data": null
}
```

专属错误码:

- 4003: 订单当前状态不可评价（如处于未完成状态）。
- 4004: 当前操作用户非该订单的参与者，无权评价。

3. AI 辅助审查与缺陷发现报告

在生成 API 规范文档的过程中，团队首先要求 AI 输出初始版本。经团队人工介入审查，发现 AI 的初始设计存在以下典型缺陷。团队已在上述最终版规范中完成了修正：

1. 接口命名不一致：

- **发现缺陷：** AI 初始生成的路径混用了动词与名词（如 /getRequirements 与 /createOrder），且未统一大小写规范。
- **修正方案：** 强制统一采用 RESTful 风格，路径仅使用名词复数。例如获取需求列表修正为 GET /requirements，发布需求修正为 POST /requirements，通过 HTTP Method 区分具体动作。

2. 缺少错误处理：

- **发现缺陷：** 初始文档仅定义了 HTTP 200 的成功返回结构，未对业务异常、并发冲突等场景进行错误码定义。
- **修正方案：** 在文档全局预定义了统一的响应外壳（包含 code, message, data），并补充了全局错误码表。针对接单等复杂业务，额外追加了 4001（需求已被接）、4003（不可评价）等具体业务级错误码。

3. 参数校验不完整：

- **发现缺陷：** 初始参数表仅列出参数名与类型，缺乏对边界条件的约束。

- **修正方案：** 补充了严格的参数边界说明。例如约束 `budget >= 0`、限制评价 `star` 在 1-5 之间、规定 `username` 与 `description` 的字符长度上下限。

4. 安全问题（未考虑认证）：

- **发现缺陷：** 初始文档未体现鉴权逻辑，任意接口均可匿名调用，存在严重的越权风险。
- **修正方案：** 明确了各接口的安全级别。除登录/注册接口外，强制规定所有核心业务接口请求时必须在 HTTP Header 中携带 `Authorization: Bearer <token>` 凭证。